

Controls and Compliance Checklist

Botium Toys — Internal Security Audit

Controls Assessment Checklist

Does Botium Toys currently have this control in place?

Yes	No	Control
	X No	Least Privilege
	X No	Disaster recovery plans
✓ Yes		Password policies
	X No	Separation of duties
✓ Yes		Firewall
	X No	Intrusion detection system (IDS)
	X No	Backups
✓ Yes		Antivirus software
✓ Yes		Manual monitoring, maintenance, and intervention for legacy systems
	X No	Encryption
	X No	Password management system
✓ Yes		Locks (offices, storefront, warehouse)
✓ Yes		Closed-circuit television (CCTV) surveillance
✓ Yes		Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance Checklist

Does Botium Toys currently adhere to this compliance best practice?

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best Practice
	X No	Only authorized users have access to customers' credit card information.
	X No	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
	X No	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
	X No	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best Practice
	X No	E.U. customers' data is kept private/secured.
✓ Yes		There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
	X No	Ensure data is properly classified and inventoried.
✓ Yes		Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best Practice
	X No	User access policies are established.
	X No	Sensitive data (PII/SPII) is confidential/private.
✓ Yes		Data integrity ensures the data is consistent, complete, accurate, and has been validated.
✓ Yes		Data is available to individuals authorized to access it.

Recommendations

Based on the audit findings, the following controls and compliance improvements should be prioritized:

1. Implement Least Privilege and Separation of Duties

Currently all employees have access to all internally stored data, including cardholder data and PII/SPII. Access should be restricted so employees can only access data required for their specific role. This is critical for both PCI DSS and SOC compliance.

2. Implement Encryption

Credit card information is not currently encrypted. Encryption must be implemented immediately to protect cardholder data at rest and in transit, and to comply with PCI DSS requirements.

3. Establish Disaster Recovery Plans and Backups

There are no disaster recovery plans or data backups in place. Critical data backups should be implemented immediately to ensure business continuity in the event of an incident.

4. Install an Intrusion Detection System (IDS)

No IDS is currently in place. An IDS would allow the IT department to detect anomalous traffic and potential intrusions in a timely manner, significantly improving the company's detection capabilities.

5. Strengthen Password Policies and Implement a Password Management System

The current password policy has nominal requirements and there is no centralized password management system. Password requirements should be updated to meet minimum complexity standards and a password manager should be deployed to reduce help desk burden and improve security.

6. Classify and Inventory Assets

Assets are not currently classified or inventoried in line with GDPR and SOC requirements. A full asset classification exercise should be conducted to identify what data is held, where it is stored, and how it should be protected.